

PROJET DEVSECOPS

# Pipeline CI sécurisée & démonstration

Harbor + Terraform — du code jusqu'au registre, sécurisé et observable.

Dylan TREPON

# Objectif & architecture

Sécuriser la livraison d'une image jusqu'à un registre privé (Harbor), de façon automatisée et observable.

1

**Infrastructure as Code**

Terraform · Helm · k3s

2

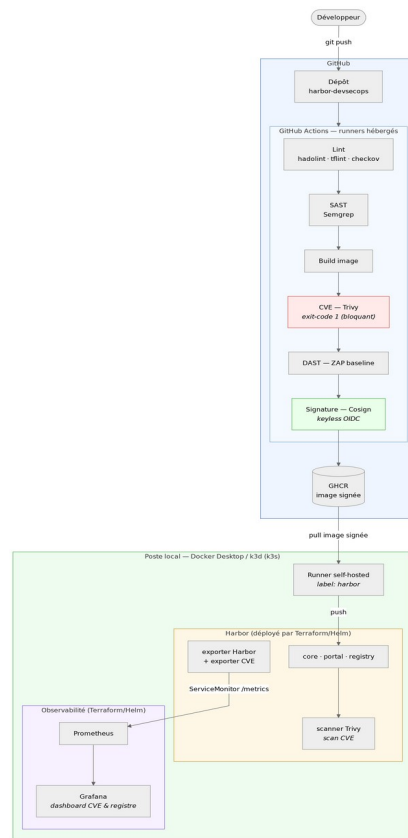
**CI sécurisée**

lint · SAST · CVE · DAST · signature

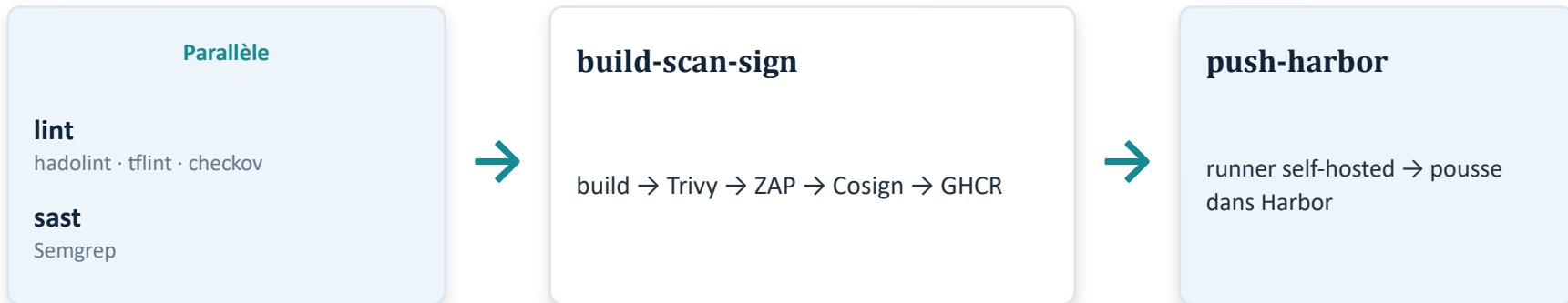
3

**Observabilité**

Prometheus · Grafana



## 4 jobs : parallèle puis séquence



Indépendants → en parallèle. Dépendants (needs) → en séquence : on ne construit pas si le code est mauvais, et on ne pousse pas une image pas encore signée.

*Déclenchée par « Run workflow » (workflow\_dispatch) pour inclure la publication vers Harbor.*

# 5 portes bloquantes

1

**Lint**

Dockerfile + IaC

2

**SAST**

Semgrep (code)

3

**CVE**

Trivy (bloquant)

4

**DAST**

ZAP (appli)

5

**Signature**

Cosign

## Bloquante

Trivy avec exit-code 1 : une CVE HIGH/CRITICAL corrigable arrête la pipeline. L'image n'est pas publiée.

## GHCR puis Harbor

L'image signée part sur GHCR (cloud), puis un runner self-hosted la pousse dans Harbor (registre local).

## DÉMONSTRATION

# Du lancement au dashboard

### 1 Lancer

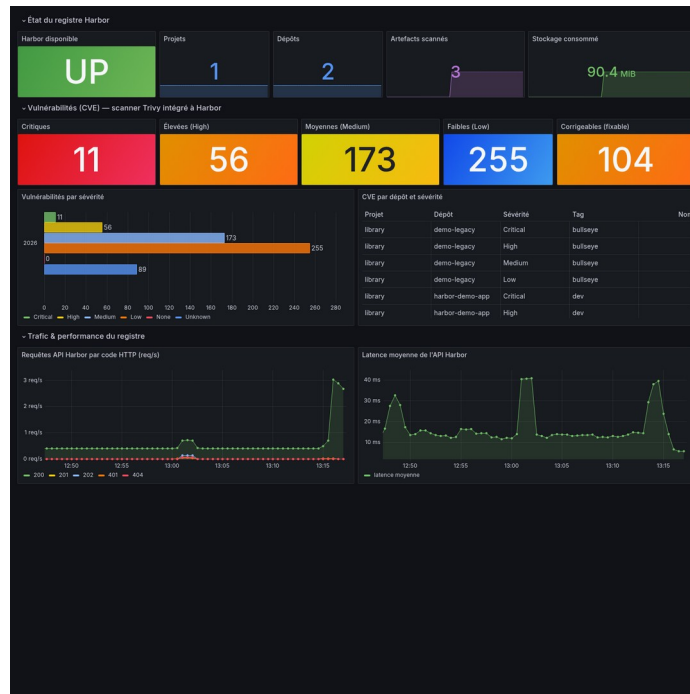
« Run workflow » → les 4 jobs passent au vert

### 2 Harbor

l'image poussée + son scan de vulnérabilités

### 3 Grafana

le dashboard des CVE par sévérité



# La pipeline bloque vraiment

## Image saine

**Trivy → exit 0**

- ✓ tous les jobs verts
- ✓ image signée
- ✓ publiée dans Harbor

## Image vulnérable

**Trivy → exit 1**

- x le job échoue (rouge)
- x push-harbor sauté
- x jamais publiée dans Harbor

*Démonstration : une image saine passe et arrive dans Harbor ; une image volontairement vulnérable est bloquée par Trivy et n'y arrive jamais.*

# Résultats

## Infrastructure

Harbor + supervision déployés par Terraform sur k3s

## Sécurité

Pipeline bloquante : lint, SAST, CVE, DAST, signature

## Observabilité

Dashboard Grafana des vulnérabilités (CVE) du registre

[github.com/KaTaKuRi-31/harbor-devsecops](https://github.com/KaTaKuRi-31/harbor-devsecops)

*Merci — je reste disponible pour vos questions.*